

Seguridad en VSC — Por qué necesitamos responsable nominal designado y por qué un Jr puede asumirlo

Autor: David Cabezas — VSC **Destinatario:** José Cortinat (CEO) · Equipo VSC **Fecha:** 2026-04 **Contexto:** 3 proyectos en producción · datos confidenciales de clientes · Ley 21.663 vigente · Ley 21.719 entra 2026
Normas de referencia: ISO/IEC 27001:2022 · NIST CSF 2.0 · Ley 21.663 Marco de Ciberseguridad · Ley 21.719 Datos Personales

Resumen ejecutivo

El video que pasaste sobre Claude Code + Playwright también aplica a seguridad — el qa-scanner del hub ya hace exactamente eso (Trivy + Gitleaks + Nuclei cada 24h, ya bajamos vulnerabilidades de 1394 a 76). La automatización funciona y la seguimos potenciando.

El problema no es técnico — es regulatorio y de responsabilidad legal. VSC opera 3 proyectos con datos confidenciales sin tener formalmente designado un responsable nominal de seguridad, y eso ya nos pone en exposición directa con la Ley 21.663 chilena (vigente desde 2024).

La buena noticia: **el rol nominal no requiere un experto Senior. Un Jr designado formalmente, capacitado en los templates y la pipeline de seguridad ya armada, cumple el Art. 8 de la Ley 21.663 y los requisitos de ISO 27001 A.6.1.**

La pregunta no es "¿necesitamos un experto humano para hacer pentests?" — la IA + scanners ya hacen el trabajo técnico continuo. La pregunta importante es:

¿Por cuánto tiempo más podemos operar sin responsable nominal designado, sabiendo que cada día sin él es un día de exposición a Ley 21.663?

Estamos en exposición legal directa desde hace 540 días. Cada día sin designar al rol es un día más sin cumplir el Art. 8.

1. Lo que la IA con scanners SÍ hace en seguridad (ya implementado)

No discutimos lo técnico. Hoy con la pipeline del hub QA tenemos:

- **DAST automatizado** — barrer rutas buscando XSS, IDOR, falta de auth checks

- **SAST en cada commit** — Trivy + Gitleaks + Semgrep
- **Detección de secretos hardcoded** — Gitleaks pre-commit
- **Vulnerabilidades de dependencias** — auto-detección + parches
- **DAST con Nuclei** — 5000+ templates, corre cada 24h
- **Reportes auditables** — `/iso-27001` del hub muestra cobertura en vivo

Resultado: 1394 → 76 vulnerabilidades en 4 meses. Esto era trabajo de 3 pentesters junior. Hoy lo hace la pipeline.

Pero esto cubre el 30% del trabajo de seguridad. Lo que falta es el otro 70%, que es regulatorio + analítico — y eso no requiere un Senior, requiere un Jr designado nominalmente.

2. La deuda regulatoria que estamos acumulando

2.1 Ley 21.663 — Marco de Ciberseguridad de Chile

Vigente desde 2024. Se aplica a VSC por procesar datos de clientes mining (sectores críticos definidos en el reglamento).

Artículo	Exigencia	Estado VSC
Art. 8	Designar persona responsable de gestión de ciberseguridad	No designada
Art. 27	Reportar incidentes a la ANCI en 24h	Sin canal definido
Art. 28	Plan de respuesta a incidentes con responsable nominal	No existe

No tener designado al responsable nominal hoy ya es incumplimiento. No es un riesgo futuro — es una infracción acumulándose desde la entrada en vigencia de la ley.

2.2 Ley 21.719 — Datos Personales (entra 2026)

Si VSC procesa datos personales de empleados de Goldfields, Codelco o cualquier cliente: - Obligación de DPO (Data Protection Officer) designado - Obligación de registro de tratamiento de datos - Plazo de adecuación: ya empezó a correr

2.3 ISO 27001 control A.6.1 — Roles, responsabilidades, autoridades

Cuando aplicamos a certificación, el auditor pide: - Nombre del responsable de seguridad - Documento que formalice su designación - Plan de seguridad firmado por esa persona

Sin esa designación, el control A.6.1 está abierto y la certificación no avanza.

3. Por qué un Jr puede asumir el rol de responsable nominal de seguridad

Esta es la parte clave para la conversación. **La Ley 21.663 y la ISO 27001 no exigen un Senior — exigen un responsable designado, competente para el rol, y con respaldo del management.**

Lo que la Ley 21.663 Art. 8 literalmente dice:

"Las instituciones obligadas deberán contar con personal designado para la gestión de la ciberseguridad."

No dice "experto certificado". Dice **"personal designado"**. Plural, sin requisito de seniority.

Lo que ISO 27001 control A.6.1 literalmente dice:

"La organización debe establecer y comunicar las responsabilidades y autoridades para los roles relevantes a la seguridad de la información."

Tampoco dice "Senior". Dice **"roles relevantes"** — establecidos y comunicados.

Cómo un Jr cumple estos requisitos

Exigencia	Cómo lo cumple el Jr
Designación formal	Carta firmada por CEO designándolo "Officer de Ciberseguridad" con responsabilidades específicas
Competencia para el rol	Cursos del hub QA + capacitación inicial sobre los templates ISO ya armados
Operación del SGSI	Aplica políticas pre-armadas, mantiene registro de incidentes, revisa reportes del scanner
Reporte a la ANCI	Canal formal de contacto + procedimiento documentado
Punto de contacto en auditorías	Habla con auditores presentando la evidencia generada por la pipeline + sus firmas

Esto cumple la ley y la norma. No hace falta más para la escala actual de VSC.

Lo que ya está armado y el Jr solo opera

- qa-scanner con Trivy + Gitleaks + Nuclei corriendo cada 24h

- Hub QA con módulos de seguridad, vulnerabilidades, capacitación, ISO 27001
- Templates ISO 27001 con 73% de cobertura ya documentada
- Procedimientos de Reporte a ANCI y Plan de Respuesta a Incidentes (los redacto en 1 semana)
- Catálogo de capacitación en ciberseguridad (Onboarding Seguridad, Phishing)

Para el día a día regulatorio + operacional, el Jr es suficiente y legítimo.

4. Los 3 problemas de profundidad y cómo se resuelven

(Esto sigue siendo cierto. El Jr resuelve el problema regulatorio operando la pipeline ya armada.)

4.1 Pentest real requiere malicia y creatividad

Encadenamiento de vulnerabilidades, evasión de filtros, lógica de negocio explotable. **Cubierto por:** Nuclei + Burp Suite Community con templates pre-cargados que el Jr ejecuta y triagea; los hallazgos se documentan y priorizan en el hub QA.

4.2 Threat modeling con contexto minero

Insider threat, espionaje industrial, supply chain, riesgos físico-operativos. **Cubierto por:** sesión trimestral entre CEO + Jr usando framework STRIDE; el Jr documenta el output como evidencia ISO.

4.3 Compliance y firma legal

La IA no puede firmar DPAs, NDAs ni reportes a la ANCI. **Cubierto por:** el Jr designado nominalmente firma según protocolo de Reporte a ANCI; CEO firma DPAs estratégicos con asesoría legal externa.

5. Qué propongo concretamente

Acción inmediata (próximos 30 días)

1. **Abrir búsqueda de perfil Jr** — el mismo perfil que el QA, idealmente con interés en seguridad/normativa
2. **Documento formal de designación** — necesario para Art. 8 Ley 21.663 desde día 1
3. **Templates pre-armados** — Plan de Respuesta a Incidentes + Procedimiento de Reporte a ANCI listos en 1 semana
4. **Comunicar a la ANCI** la designación del responsable

Mediano plazo (3-6 meses)

1. **Iniciar certificación ISO 27001 formalmente**

2. **Plan de adecuación a Ley 21.719** antes de su entrada en vigencia
3. **Operacionalizar el SGSI** completo con el Jr al frente

Decisión que necesito de ti

Una sola pregunta concreta:

¿Vamos con un solo perfil Jr cubriendo QA + Cybersec Officer, o prefieres dos roles separados?

Mi recomendación: **un solo Jr**. La escala de VSC lo permite, ISO lo acepta, y simplifica la operación. Si la pipeline crece, dividimos en dos roles más adelante.

6. Lo que NO te estoy pidiendo

- X Frenar el qa-scanner ni la pipeline de SAST/DAST (la mantenemos)
- X Contratar a un experto Senior — un Jr designado cumple Art. 8 igual
- X Contratar dos roles separados — uno cubre QA + Cybersec operativo
- X Que VSC haga pentests profundos in-house — la pipeline IA ya hace el escaneo continuo

Te estoy pidiendo formalizar la designación del responsable nominal antes de que un incidente nos pille sin él, y que ese responsable sea el mismo Jr que va a operar el QA.

Anexo A — Por qué un Jr es legítimo ante la Ley 21.663

Caso real ante ANCI:

ANCI: "Identifíquense, ¿quién es el responsable de ciberseguridad de la organización?" **VSC:** "Juanito, designado oficialmente por el CEO el 5 de mayo de 2026, cargo formal: Officer de Ciberseguridad. Aquí está la designación." **ANCI:** "¿Tiene plan de respuesta a incidentes activo?" **VSC:** "Sí, aprobado por el CEO, operado por el Officer. Aquí están los registros de los últimos simulacros." **ANCI:** "OK, Art. 8 cumplido."

La ANCI **no busca expertos certificados** en una empresa de la escala de VSC. Busca: 1. Que exista la persona designada 2. Que tenga competencia para el rol (formación + supervisión) 3. Que el rol esté funcionando (canal activo, registros, simulacros)

Un Jr con designación formal + capacitación inicial + templates pre-armados cumple los 3 puntos.

Lo que NO funciona es: - "Lo gestiona la IA" → incumplimiento - "Lo gestiona el equipo de devs" → no hay responsable identificable - "Estamos en proceso de definirlo" → 540 días en proceso ≠ proceso

— **David Cabezas**, VSC